# SIZMA TESTİ RAPORU

| | |
|---|---|
| **Rapor Tarihi** | 07/08/2026 |
| **Hazırlayan** | Ömer Faruk Baysal |
| **Test Türü** | PortSwigger Web Academy Lab |

## 1. SQL injection vulnerability in WHERE clause allowing retrieval of hidden data

Bu raporda PortSwigger Web Security Academy'de yer alan "SQL injection vulnerability in WHERE clause allowing retrieval of hidden data" labı ele alınmıştır.

## 2. Yönetici Özeti

Yapılan test sonucunda, hedef uygulamanın ürün filtreleme özelliğinde zafiyet bulunmuştur. Bu zafiyet, saldırganın hedef sunucuda sql komutları çalıştırmasına ve sisteme yetkisiz erişim sağlamasına olanak tanımaktadır. Zafiyetin ivedilikle giderilmesi önerilmektedir.

## 3. Zafiyet Açıklaması

İlgili hedef sitede, product filtreleme özelliğinde SQL injection zafiyeti tespit edilmiştir. Kullanıcı ürünle ilgili kategori filtresini seçtğinde SQL sorugusu aşağıdaki gibi dönmektedir:

*>SELECT * FROM products WHERE category = 'Gifts' AND released = 1*

Labın çözülmesi için SQL injection attack uygulanarak yayınlanmamış ürünlerden sergilenilmesi isteniyor.

## 4. Risk Seviyesi

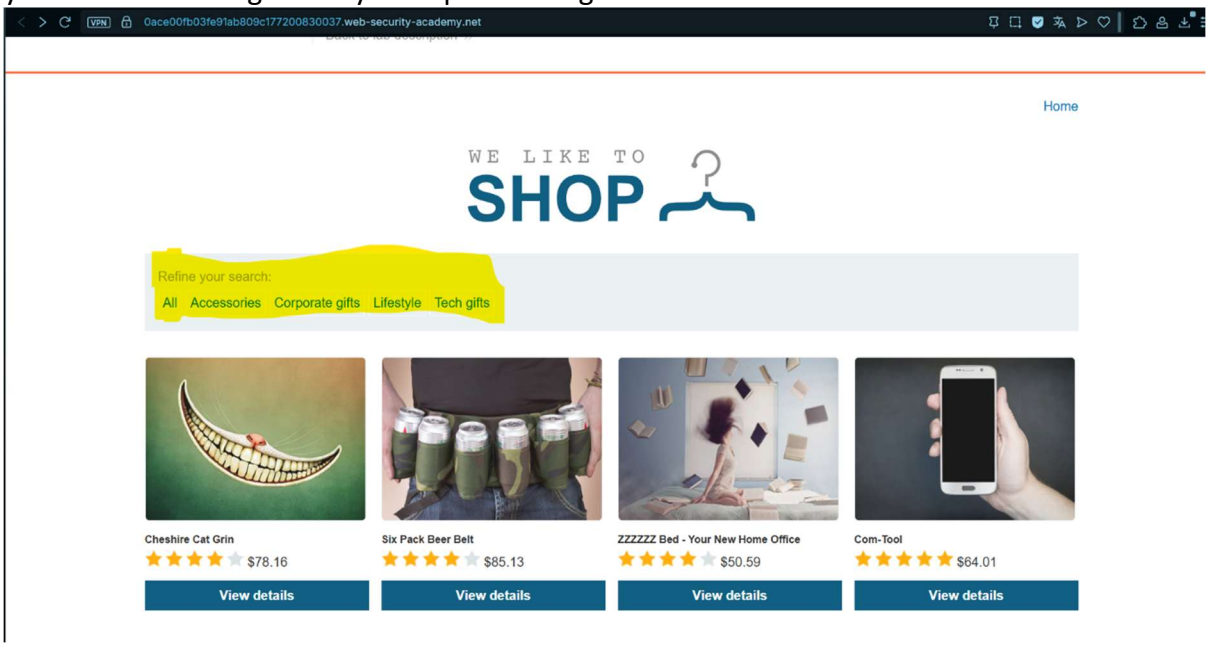
| | |
|---|---|
| **Risk Seviyesi** | Kritik |
| **CVSS v3.1 Skoru** | 7.5 |
| **CWE** | CWE-89 |

## 5. Etki

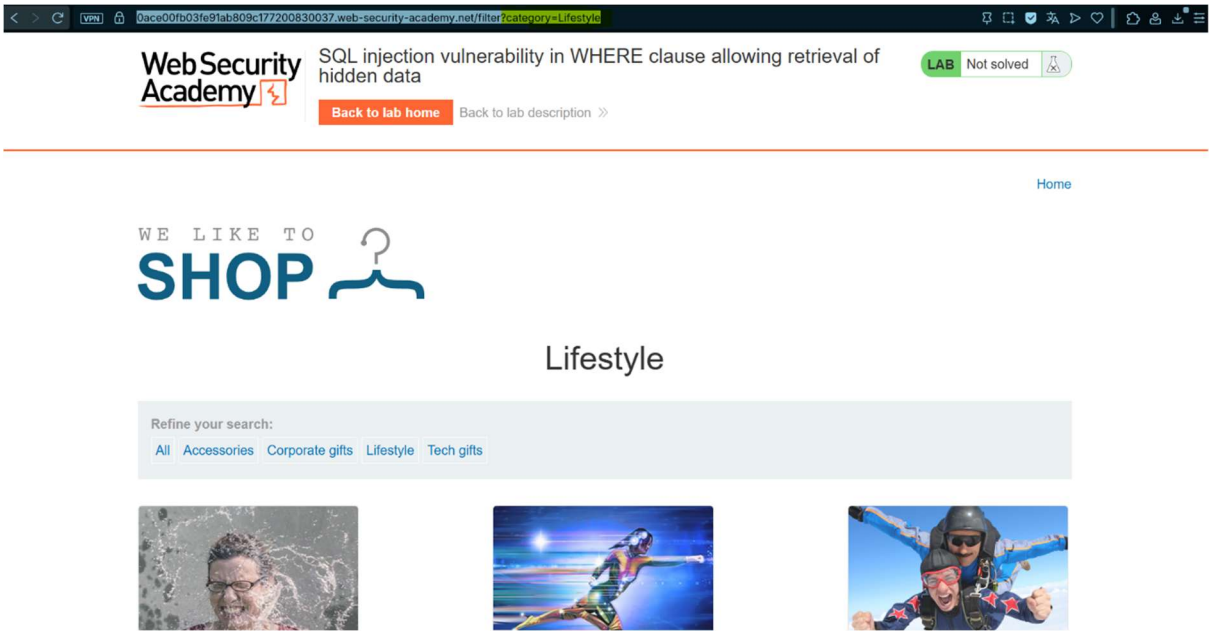
Bu zafiyetle birlikte, normalde uygulamanın göstermediği yayınlanmamış ürünlere yetkisiz erişim sağlanabileceği ve SQL sorgusunun değiştirilebileceği kanıtlanmıştır.
Aynı zafiyet, uygulamanın yetki seviyesine ve veritabanı yapılandırmasına bağlı olarak veritabanındaki tüm verilerin (kullanıcı bilgileri, parolalar vb.) ele geçirilmesine, kimlik doğrulama mekanizmasının atlatılmasına ve bazı durumlarda hedef sistemde komut çalıştırılmasına kadar ilerleyebilir.

## 6. Proof Of Concept

İlgili hedef siteye girildiğinde ürünleri filtreleme kategorisi karşımıza çıkmaktadır. Deneme amaçlı bir filtreye tıkladığımızda sitenin bizi başka bir url'e yönlendirildiği görülecektir. Örneğin "Lifestyle" kategorisine tıklarsak bizi "..filter?category=Lifestyle" ile biten bir url'e yönlendirecek ve ilgili filtreye sahip ürünleri gösterecektir.

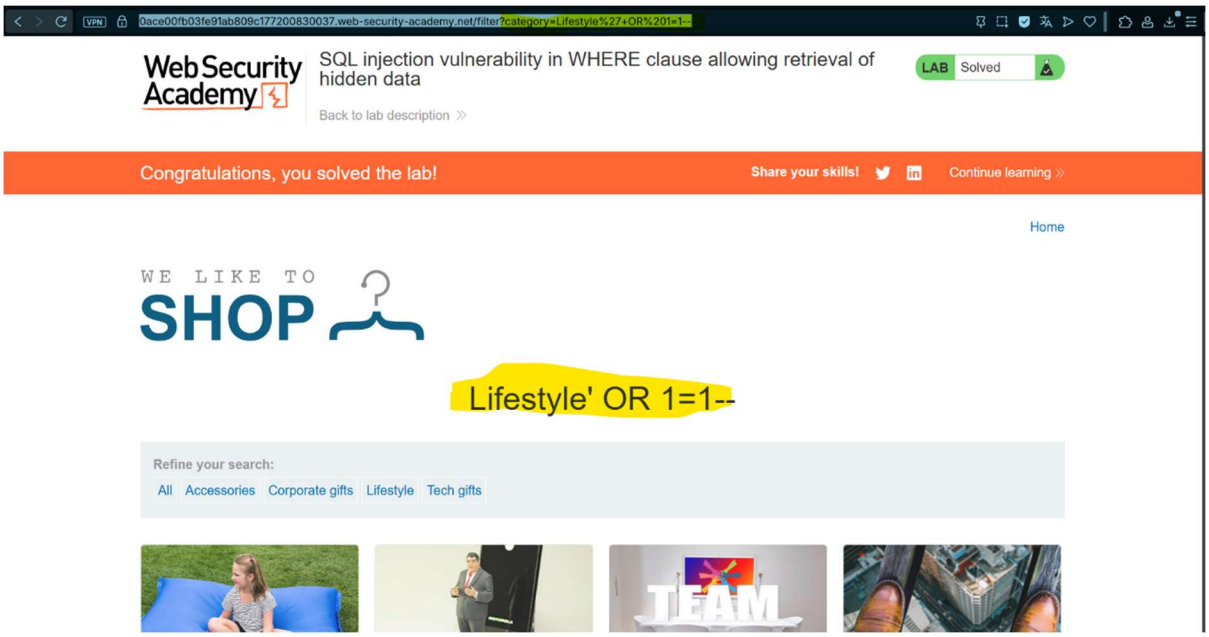



*İlgili site ana sayfası*

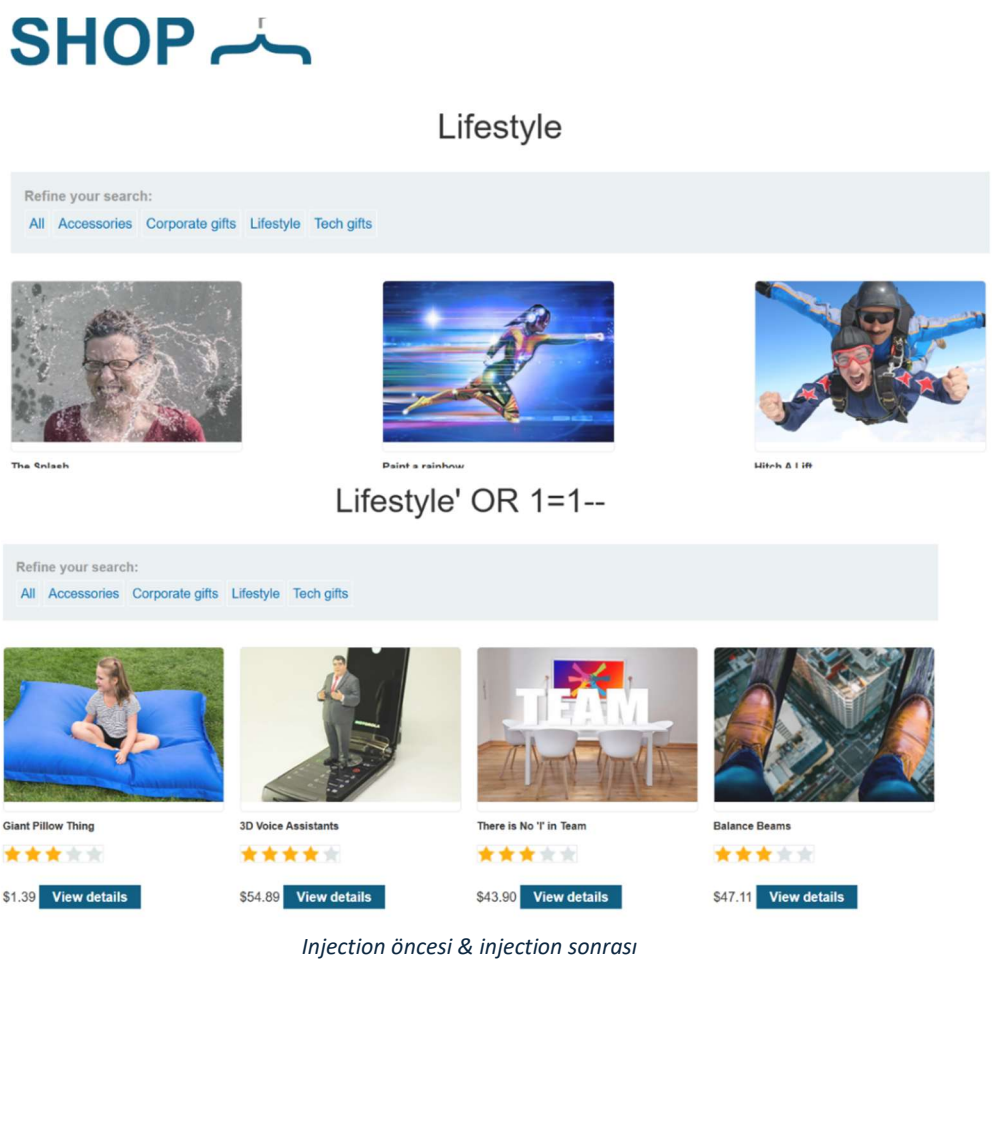



*Url'de filtreleme gözükmektedir*

Buradaki urlde bir sql injection denemesi yaparsak:
>http….filter?category=Lifestyle'+OR+1=1—payloadını yazıp onayladığımızda payload çalışacaktır ve yayımlanmamış ürünler de gözükecektir.




*Payload çıktısı*




*Injection öncesi & injection sonrası*

## 7. Çözüm Önerisi

Parametrik sorgular kullanılmalıdır. Kullanıcı girdisi, SQL sorgusuna doğrudan string olarak birleştirilmemelidir. Bunun yerine, sorgu yapısı ile kullanıcı verisini ayrı işleyen parametrik sorgular kullanılmalıdır. Bu sayede kullanıcı girdisi, SQL kodu olarak değil yalnızca veri olarak yorumlanır ve zafiyet kökten önlenir.

Girdi doğrulama uygulanmalıdır. Kullanıcıdan gelen veriler, beklenen türe ve formata göre doğrulanmalıdır.

Uygulamanın kullandığı veritabanı hesabına yalnızca ihtiyaç duyduğu minimum yetkiler verilmelidir. Böylece olası bir injection durumunda etkinin (veri sızıntısı, komut çalıştırma) kapsamı sınırlandırılmalıdır.

## 8.Sonuç

Testin sonucunda hedefin sql enjeksiyonuna açık olduğu doğrulanmıştır.

---